1.1 Purpose

Why the policy is needed?

This policy provides guidance for the management, processing and protection of Halma and its subsidiaries' data assets. All Halma and its subsidiaries' employees and providers share in the responsibility for ensuring that data assets receive the appropriate level of protection and privacy by observing this policy.

Note:

1) All references to data will include data whether processed by automated means or not
2) Personal data is defined as per the GDPR (Regulation (EU) 2016/679) Article 4(1)[i] and includes special categories (Article 9(1)[ii] or as amended by the UK Data Protection Bill when released
3) Processing is defined GDPR (Regulation (EU) 2016/679) Article 4(2)[iii] or as amended by the UK Data Protection Bill when released.

How is the policy used?

All data and information systems should be classified as per **Table 1. Data Classification.**

This policy is designed to be 'layered' with subsidiaries providing local adaptations as necessary while still supporting the intent of this policy.

What related requirements (policies, standards, regulation, legislation etc.) are relevant?

The following outlines the compliance considerations within the scope of this policy:

- GDPR and the UK Data Protection Bill (when released)

What local variants of the above are relevant to <Halma Subsidiary name>?

- <Local legislation, regulation, law etc.>
- <Standards (internal and external) as adopted by the subsidiary that are relevant to this policy.>

Note: all local variants to be communicated with <Halma HO> for vetting and impact/risk analysis where relevant.

1.2 Scope

What is covered in the policy?

All data, data technology and manual systems, processing.

1.3 Audience

Who is the policy aimed at?

All Halma and its subsidiaries' parties involved in the processing of data.
Identified management will have the following responsibilities:

- Adhering to the rules for the appropriate and acceptable use, protection and privacy of the data whether at rest (storage) or in motion (transmission)
- Communicating the consequences and obligations of their access to data
- Identifying individual and system access and privileges (and revocation of these) to identified data and manual systems
- Working with Halma IT security to ensure the optimum functioning of Group-specified controls (or locally identified and implemented) and provide signoff on an agreed basis that the controls are effective
- Ensure that they maintain current understanding of data handling (defined here as per Section 1.1, Note 3) from Halma or its subsidiaries' <data governance committee, General Counsel, DPO or equivalent>.

1.4 Policy Statement

Specifics of the policy

- All parties that process data must:
  - Ensure the protection and processing of Halma data is consistent with its classification
  - Ensure that the handling (as per processing identified earlier) of data comply with all relevant business, legal and regulatory requirements
  - Review periodically with local management/board of directors the classification of data they process against the Halma Data Classification scheme and handling.
- All data must be:
  - Labelled appropriately (where possible) and managed in accordance with the Data Handling Guidelines set out below

  - Destroyed in such a manner as to avoid unauthorised or accidental disclosure
- All personal data must be[iv]:
  - Processed lawfully[v], fairly and in a transparent manner in relation to individuals
  - Collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes
  - Adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed
  - Accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay
  - Kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed – see Halma Data Retention Guidelines
  - Processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures.

1.4.1 Breach

Where a breach[vi] occurs by either Halma (as controller) or one of its subsidiaries or partners outside the group (as controllers, joint controllers or processors), the affected parties' Breach Notification[vii] must be invoked.

1.4.2 Classification Scheme

This scheme identifies classification levels that must be used when identifying requirements for processing data.

Classification	Type	Description	Impact	Protection
Public	Public	The data is not confidential and can be made public without any implications for Halma	Could reasonably be expected to cause: - Limited financial losses - Limited impact in service level - Performance, embarrassment and inconvenience	**Confidentiality** - Content that can be found on public-facing Halma web sites - Public financial reports filed to regulatory bodies - Newsletters/articles for external transmission - General corporate data - Some technical data

Classification	Type	Description	Impact	Protection
				Integrity - Internal data with no legal effect **Availability** - Certain delay to access the data is tolerable
Private [default]	Proprietary or customer	Data is restricted to management approved internal access and protected from external access unless essential Unauthorised access could influence Halma's operational effectiveness **This is the default classification for data and data assets**	Could reasonably be expected to cause: - Loss of competitive advantage - Loss of confidence (public, investor, provider) - Significant financial loss - Legal action - Damage to partnerships, relationships and reputations	**Confidentiality** - Standard policies, processes and operating procedures - Standard T&Cs and non-disclosure agreements with our suppliers - Most personnel or personally identifiable data - Non-critical parts of Halma developed software - Disclosure of trade secrets or intellectual property **Integrity** - Data relating to non-critical or confidential processing - Financial transactions and payments - Data that could be used for criminal purposes (e.g. false identity or impersonation) **Availability** - Financial and management data systems
Restricted	Company or customer confidential data	The highest levels of confidentiality, integrity and restricted availability are vital Unauthorised access could severely impact Halma, leading to: - Severe	Could reasonably be expected to cause any combination of: - Extremely significant financial loss - Loss of confidence (public, investor, provider) - Social hardship - Major	**Confidentiality** - Some accounting data and internal financial reports - Data relating to criminal activity (e.g. fraud) - Confidential contracts and customer/Halma business data - Company business plans - Customer details (including transmission of customer data to and from providers)

Classification	Type	Description	Impact	Protection
		financial loss - Significant gain to a competitor - Reduction in customer confidence - Reputational damage	reputational or economic impact	- Critical parts Halma-developed software (intellectual property) **Integrity** - Extended loss of service resulting in the need to institute manual processes - Significant financial transaction transfers **Availability** - Communication during business or disaster interruption

Table 1. Data Classification Scheme

The **Private** classification will be used as the default classification. This assumes a risk-averse position as will also require formal intervention of classification where no classification has been assigned. It should be noted that in cases where no classification has been assigned that the default of **Private** may restrict access and visibility limitations. This is by design and therefore requires formal classification to be undertaken by each business unit within Halma and its subsidiaries.

1.4.2.1 Classification Activities

Data classification is based on the level of sensitivity and the impact on Halma or its subsidiaries should that data be disclosed, altered or destroyed without authorisation. This also assist in determining what baseline security controls are appropriate for safeguarding data. All Halma data should be classified into one of the 3 classifications:

- Public Data
  - Data should be classified as **Public** when the unauthorized disclosure, alteration or destruction of that data would result in little or no risk to Halma or its affiliates (providers, customers)
    - Examples of **Public** data include press releases, public-media-based data and similar publications
  - While little or no controls are required to protect the confidentiality of **Public** data, some level of control is required to prevent unauthorized modification or destruction of **Public** data
- Private Data (default classification)

- Data should be classified as **Private** when the unauthorised disclosure, alteration or destruction of that data could result in a moderate level of risk to or its affiliates (providers, customers)
- By default, all Halma Data that is not explicitly classified as **Restricted** or **Public** data should be treated as **Private** data
- Security controls must be applied to **Private** data.

- Restricted Data
  - Data should be classified as **Restricted** when the unauthorised disclosure, alteration or destruction of that data could cause a significant level of risk
  - Examples of **Restricted** data include strategic plans, financials, succession plans etc. and those protected by UK and EU privacy regulations, contract, seals and certifications, confidentiality agreements (please see 1.4.5) etc.
  - The highest level of security controls should be applied to **Restricted** data.

This policy requires the following goals to be considered across the data lifecycle (collect to destroy):

Protection	Description
Confidentiality	Preserving authorised restrictions on data access and disclosure, including means for protecting personal privacy and propriety data A loss of confidentiality is the unauthorized disclosure of data
Integrity	Guarding against improper modification or destruction (includes ensuring data non-repudiation and authenticity) A loss of integrity of change outside the bounds of permitted functionality – resulting in loss of auditability
Availability	Ensuring timely and reliable access to and use of data A loss of availability is the disruption of access to or use of data or a data system

Table 2. Security Goals

1.4.3 Data Handling Guidelines

Data handling must be guided by the following with reference to the Data Classification Scheme to identify what is required during the identified activities below:

Public	
Access	No restrictions
Internal distribution	Freely available
External distribution	As required
Storage	Store as normal
Retention Period	Refer to Halma Data Retention Guidelines
Disposal/destruction	Via business-approved methods
Private	
Access	Employees or associates who have a business need to know
Internal distribution	For data via approved electronic file transmission and encryption methods (e.g. internal e-mail system) For hardcopy via internal mail system
External distribution	For data via approved electronic transmission methods – note, if sending via e-mail then the relevant e-mail encryption facility available in the current Halma office suite For hardcopy via approved distribution lists and normal distribution channels – signature on receipt as required For hardcopy via internal mail system in envelopes marked 'confidential addressee only'
Storage	For electronic data via individual access control For hardcopy clean desks and secure cabinet as required
Retention Period	Refer to Halma Data Retention Guidelines
Disposal/destruction	For data treat as *Restricted* For hardcopy similar – use confidential waste bins
Restricted	
Access	Restricted access to only those employees or associates who have a business need to know, who have designated access rights and who have signed a non-disclosure agreement
Internal distribution	For data via approved electronic file transmission methods (e.g. encrypted USB stick; internal e-mail system where distribution lists are approved and document can be password protected) For hardcopy via internal mail system in envelopes marked 'confidential addressee only'
External distribution	For data via approved electronic file transmission methods For hardcopy via approved private courier requiring signature on delivery
Storage	For electronic data via a secure computing environment and individual access controls which may include encryption For hardcopy via secure storage (locked cabinet or safe)
Retention Period	Refer to Halma Data Retention Guidelines
Disposal/destruction	For data via secure disposal or destruction by approved/secure data disposal service with certificated evidence. For hardcopy via confidential waste bins

Table 3. Data Handling Guidelines

1.4.4 Operational Requirements

When data is transmitted internally or externally:

- Data and related media transferred (whether on physical, electronic, visual or audio format) must be suitably marked and identified so that recipient organisations are able to implement the appropriate protection
- The storage and access of transmitted data by the recipient shall also be consistent with the classification rating
  - This will include a combination of technical and organisational measure including: backup measures, encryption, firewalls, intrusion detection systems and related internal or external network defences, physical protection of media and related storage devices, handling and disposal of media and printouts, user authorization and authentication
- Specific requirements unique to each jurisdiction where the data is processed, such as those required by legislation, policies, or standards, must be documented, approved and implemented with the necessary management controls in place for periodic review and for assurance purposes

Where an individual document is being created that has not been tagged with classification metadata by the document management system or by having its classification pre-populated from a template, the document author must add the classification status to the document, preferably in the properties, title page and the header of the document.

The classification status of a document may change over time (i.e. a document may have a Restricted classification early in its lifecycle, but this may be downgraded to a Private classification as time progresses). Regular reviews of classifications are vital.
While tagging individual data attributes can be done this will likely not be possible for every form of database or filing system. In these cases, Halma and its subsidiaries will ensure that all necessary security provisions are implemented to ensure controlled role-based access and where possible that all access and processing is audited.

1.4.5 Operational Requirements for Personal Data Handling

Where personal data is transferred intra- or extra-Halma (within the same jurisdiction or across jurisdictions) and with respect to territorial scope per Article 3 of the GDPR, Halma and its subsidiaries should seek General Counsel's view on adequate jurisdictions and other adequacy mechanisms including the use of Privacy Shield[viii], BCRs[ix] and SCCs[x]. Halma must undertake DPIAs[xi] (data protection impact assessment, Article 35 of the GDPR) as required to ensure that any relevant public, private or criminal risk is quantified and reported to the DPO or functional equivalent.

1.5 Responsibilities

Who must do what?

All parties processing data are responsible for maintaining the correct classification of their data to ensure that the appropriate security controls are applied.

---

[i] 'personal data' means any data relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;

[ii] racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation

[iii] 'processing' means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;

[iv] See GDPR Article 5(1) for further detail

[v] See GDPR Article 6(1) for further detail. Briefly:

(a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes

(b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract

(c) processing is necessary for compliance with a legal obligation to which the controller is subject

(d) processing is necessary in order to protect the vital interests of the data subject or of another natural person

(e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller

(f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

[vi] A breach is defined as a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed.

[vii] It is imperative that each subsidiary develops and maintains its own Breach Notification process.
[viii] The EU-U.S. and Swiss-U.S. Privacy Shield Frameworks were designed by the U.S. Department of Commerce, and the European Commission and Swiss Administration, respectively, to provide companies on both sides of the Atlantic with a mechanism to comply with data protection requirements when transferring personal data from the European Union and Switzerland to the United States in support of transatlantic commerce
[ix] Mechanisms/agreements that allow multinational companies to transfer personal data from the European Economic Area (EEA) to their affiliates located outside of the EEA in compliance with the 8th data protection principle and Article 25 of Directive 95/46/EC
[x] SCCs (standard contract clauses) or model contracts were created by the EU Commission for data transfers and determined that organizations which these offer sufficient safeguards for cross-border data transfer as required by the Directive. The EU Commission has issued three Model Contracts: Two for transfers from data controllers to data controllers established outside the EU, and one for a transfer to a data processor outside the EU
[xi] A mechanism designed to enable organisations to work out the risks that are inherent in proposed data processing activities before those activities commence. This, in turn, enables organisations to address and mitigate those risks before the processing begins